

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to explain the purpose and structure of Common Criteria (ISO/IEC 15408) and correctly interpret EAL ratings as measures of evaluation rigour rather than security strength.
- By the end of this lecture, you will be able to distinguish the four FIPS 140-2 security levels and explain what each level's requirements mean for the physical and logical security of a cryptographic module.
- By the end of this lecture, you will be able to describe the FedRAMP authorisation process, identify its three impact levels aligned to FIPS 199, and explain the role of Third Party Assessment Organisations.
- By the end of this lecture, you will be able to differentiate between SOC 1, SOC 2, and SOC 3 reports and explain why a SOC 2 Type II report is the appropriate assurance artefact when evaluating a cloud service provider's security posture.
- By the end of this lecture, you will be able to apply this verification framework to a CSP evaluation scenario, selecting the appropriate assurance reports and certifications for a given regulatory context.

Introduction

When an organisation moves workloads to a cloud service provider, it enters a trust relationship in which the provider controls infrastructure that the customer cannot physically inspect. In a traditional data centre, an organisation can audit its own racks, inspect its own configurations, and verify its own controls directly. In the cloud, the hypervisor, the physical host, and the core network fabric are managed by a third party whose internal operations are opaque. The mechanism that converts this blind faith into evidence-based assurance is rigorous, independent evaluation — and understanding the specific frameworks through which that evaluation is conducted is a core competency for a Cloud Security Practitioner.

This lecture introduces four of the principal evaluation and assurance frameworks that cloud practitioners must understand: Common Criteria (formalised as ISO/IEC 15408), which defines how the security properties of IT products are independently evaluated; FIPS 140-2 and its successor FIPS 140-3, which define security levels for cryptographic modules; FedRAMP, the US government's cloud-specific authorisation programme; and the SOC report family — SOC 1, SOC 2, and SOC 3 — which are the independent assurance reports most commonly used in commercial cloud evaluation contexts.

Each framework addresses a different layer of the trust question. Common Criteria asks whether a product's security properties have been independently verified. FIPS 140 asks whether the cryptographic mechanisms protecting data meet a defined standard for implementation security. FedRAMP asks whether a cloud service meets the US federal government's security baseline and has been independently assessed to confirm it. SOC 2 asks whether the controls a cloud provider claims to operate were actually operating effectively over a

meaningful period of time. Together, these frameworks form a vocabulary of evidence that allows a rigorous evaluation of whether a provider is doing what the shared responsibility model requires of them.

Core Concepts Explained

Common Criteria and EAL Ratings (ISO/IEC 15408)

Definition: Common Criteria is an international standard (ISO/IEC 15408) for evaluating the security properties of IT products. Products are evaluated by accredited testing laboratories against a Protection Profile that defines the security requirements for a given product category. A successful evaluation produces an Evaluation Assurance Level (EAL) rating from EAL1 through EAL7, indicating the rigour of the evaluation methodology applied.

Business relevance: Common Criteria provides a standardised, internationally recognised basis for comparing the security assurance of IT products — operating systems, cryptographic libraries, firewalls, hardware security modules, smart cards, and other security-relevant components. Government procurement processes in many countries require Common Criteria certification for security-critical components, and cloud providers offering services to regulated industries may use Common Criteria certifications for components of their stack as part of their overall security assurance package.

Cloud Security Practitioner relevance: A Cloud Security Practitioner reviewing a cloud provider's security assurance documentation may encounter Common Criteria certificates for provider-managed hardware or software components. The critical skill is interpreting what an EAL rating actually means: EAL4, the highest level commonly found in commercial products, indicates that the product has been evaluated with methodical design review, testing, and independent review of developer documentation — it does not mean the product has no vulnerabilities, and it does not speak to the strength of the security features themselves, only the rigour with which they were evaluated.

Real-world example: A government agency evaluating a cloud provider for a sensitive but unclassified workload required that the provider's hardware security module, used to manage encryption keys for data at rest, hold a Common Criteria certificate at EAL4 or above. The provider's HSM held an EAL4+ certificate from an accredited German testing laboratory, meaning the evaluation had been conducted against the Protection Profile for Hardware Security Modules at the methodical design and testing level, with augmentations applied. The agency's security officer noted that EAL4+ was not a claim that the HSM was vulnerability-free — it was a claim that its security design had been independently examined with a defined degree of rigour, and that no material defects were identified during the evaluation. This distinction — between rigour of evaluation and inherent security strength — is the most important conceptual point about Common Criteria ratings.

Risks or limitations: The most common misinterpretation of Common Criteria is treating a higher EAL number as meaning a more secure product. A product evaluated at EAL7 has been subjected to the most formal and rigorous verification methodology, but a product with sophisticated security features evaluated at EAL2 may protect data more effectively than a simpler product at EAL6. EAL levels speak to the evaluation process, not to the security architecture. The best practice is to use Common Criteria certificates as evidence of evaluation rigour while separately assessing the security features themselves against the threat model.

FIPS 140-2 and FIPS 140-3: Cryptographic Module Validation

Definition: FIPS 140-2, published by NIST, defines four security levels for cryptographic modules — the hardware and software components that perform encryption, decryption, hashing, key generation, and key management. FIPS 140-3, published in 2019 and built on ISO/IEC 19790, has replaced FIPS 140-2 for new

validations. Validation is conducted through NIST's Cryptographic Module Validation Programme using accredited testing laboratories.

Business relevance: FIPS 140-2 and 140-3 validation is a meaningful assurance for regulated industries and government customers because it confirms that a specific cryptographic module implementation has been independently tested to perform its security functions correctly and to meet defined physical or logical security requirements. For cloud customers in regulated sectors — federal government, defence, financial services, healthcare — the requirement to use FIPS-validated cryptographic modules may be a compliance obligation, not merely a preference.

Cloud Security Practitioner relevance: A Cloud Security Practitioner evaluating a cloud provider's encryption capabilities should verify whether the provider's cryptographic modules are FIPS 140-2 or 140-3 validated, and at which security level, before placing regulated workloads on the platform. The practitioner should also understand the difference between a provider claiming to use FIPS-approved algorithms (which is a software configuration claim) and the provider's modules being independently validated through the CMVP (which is a third-party assurance claim).

Real-world example: A US federal agency preparing to migrate a law enforcement data system to a commercial cloud provider received the provider's security documentation, which described its encryption as using AES-256 with FIPS-approved algorithms. The agency's security officer flagged that using approved algorithms is not the same as having FIPS 140-2 validated modules. The security officer searched the NIST CMVP certificate list and found that the provider's key management service had a FIPS 140-2 Level 2 validation certificate, while the provider's hardware security module service had a Level 3 certificate. For the law enforcement data system, the agency determined that Level 3 validation was required based on the sensitivity of the data and selected the HSM-backed key management option accordingly. The distinction between algorithm-level claims and module-level validation was the difference between marketing language and auditable assurance.

Risks or limitations: A persistent risk is confusing claims about algorithm strength with validated module security. Using AES-256 is a statement about the cipher selected; having a FIPS 140-3 validated module is a statement about the implementation quality and physical security of the device executing that cipher. An algorithm with known strength can still be implemented insecurely. The best practice for regulated workloads is to require FIPS 140-2 or 140-3 module validation at the appropriate level as a contract requirement, and to verify the certificate on the NIST CMVP list rather than accepting the provider's claims at face value.

FedRAMP: Federal Cloud Security Authorisation

Definition: The Federal Risk and Authorization Management Program (FedRAMP) is a US government programme that provides a standardised approach to security assessment, authorisation, and continuous monitoring for cloud services used by US federal agencies. Authorisation is based on assessment by an accredited Third Party Assessment Organisation (3PAO) and is granted by either a sponsoring federal agency or the FedRAMP Joint Authorization Board (JAB). Three impact levels — Low, Moderate, and High — align to FIPS 199 security impact categories.

Business relevance: FedRAMP authorisation is effectively a market access requirement for cloud providers seeking to serve the US federal government. It is also a rigorous, publicly documented assurance that the authorised service meets a defined baseline — the NIST SP 800-53 control set appropriate to the impact level. For non-government customers in regulated industries, a provider's FedRAMP authorisation can serve as an independent indicator of security programme maturity even when the specific FedRAMP programme requirements do not apply.

Cloud Security Practitioner relevance: A Cloud Security Practitioner working in a government context must understand FedRAMP authorisation as the primary mechanism for validating a cloud provider's security

posture for federal use cases. The practitioner must be able to distinguish the three impact levels and map a specific workload's data classification to the appropriate level. The practitioner must also understand the role of the 3PAO — an accredited, independent organisation that conducts the assessment — as distinct from the provider's own compliance claims.

Real-world example: A federal healthcare agency was evaluating two cloud providers to host a patient-matching system for a national health data exchange. The data included individually identifiable health information and met the definition of a High impact system under FIPS 199 — a compromise could have severe or catastrophic consequences for patient safety and privacy. Provider A held a FedRAMP Moderate authorisation; Provider B held a FedRAMP High authorisation. The agency's security officer determined that a Moderate authorisation covered the baseline for approximately 80 percent of federal systems but was insufficient for a High impact system, which requires an additional and substantially more demanding control baseline. Provider B was the only eligible option. The 3PAO assessment report for Provider B's High authorisation, available through the FedRAMP marketplace, provided the agency with the independent evidence of control effectiveness it needed to make a fully evidenced risk acceptance decision. This is FedRAMP operating as designed: reducing the duplication of security assessment effort across agencies while ensuring that the assessment itself is independent and rigorous.

Risks or limitations: A common mistake is assuming that a FedRAMP Moderate authorisation is sufficient for any federal workload. The three impact levels reflect the actual potential consequences of a security failure for the specific system and data in question — Low for limited adverse effects, Moderate for serious adverse effects, High for severe or catastrophic effects. Placing a High impact workload on a Moderate-authorized service is a risk acceptance decision that requires explicit approval at an appropriate level, not a default. The best practice is to classify the data and the system before selecting the provider rather than selecting the provider first and then attempting to justify the classification.

SOC Reports: SOC 1, SOC 2, and SOC 3

Definition: SOC (System and Organization Controls) reports are independent assurance reports produced by Certified Public Accountants following AICPA standards. SOC 1 addresses controls relevant to financial reporting. SOC 2 assesses a service organisation's controls against five Trust Service Criteria: security (mandatory), availability, processing integrity, confidentiality, and privacy. SOC 3 is a public summary of a SOC 2 report. SOC 2 reports are issued as Type I (point-in-time design assessment) or Type II (operational effectiveness over a defined period, typically six to twelve months).

Business relevance: SOC 2 Type II reports are the most practically useful assurance artefact in commercial cloud procurement. They provide independent, third-party evidence that the security, availability, and confidentiality controls a provider claims to operate were actually operating effectively over a sustained period. This addresses the fundamental challenge of cloud trust: the customer cannot inspect the provider's operations directly, but an accredited auditor can, and their findings are documented in a standardised format that security teams know how to interpret.

Cloud Security Practitioner relevance: A Cloud Security Practitioner evaluating a cloud provider must request the SOC 2 Type II report and review it for the scope of the criteria covered, the period covered, any exceptions noted by the auditor, and the specific controls tested. The practitioner should verify that the controls described in the report cover the services the organisation intends to use and that no material exceptions in the report relate to the controls most relevant to the organisation's risk profile. Where exceptions exist, the practitioner assesses the provider's remediation response and determines whether the residual risk is acceptable.

Real-world example: A financial technology company was evaluating two cloud database services for a workload processing payment card data. Both providers supplied SOC 2 reports. Provider A's report was a Type

I — a point-in-time assessment confirming that controls were suitably designed as of a specific date. Provider B's report was a Type II covering a 12-month period, with testing confirming that access controls, encryption key management, and audit logging controls had operated effectively throughout the period, with no exceptions noted. The company's compliance team accepted Provider B's report as adequate assurance. Provider A's Type I report, while useful as a design assessment, could not confirm that the controls were operating consistently over time — a critical distinction for a financial workload subject to PCI DSS. The company requested that Provider A provide a Type II report for the next audit period before any payment card data was committed to that service. This is the correct professional position: Type I reports confirm design; Type II reports confirm operation. Cloud security evaluation requires the latter.

Risks or limitations: A frequent error is accepting a SOC 3 report or a SOC 2 Type I report as equivalent to a SOC 2 Type II. SOC 3 is a public summary lacking the control detail and testing results needed for security evaluation. SOC 2 Type I confirms controls were designed adequately at a point in time; Type II confirms they operated effectively over a period. For cloud security purposes, only the Type II provides meaningful operational assurance. The best practice is to require SOC 2 Type II as a vendor qualification criterion and to review the full report rather than a summary, paying particular attention to the exceptions section.

Practical Applications

The following scenarios demonstrate how cloud security practitioners apply CSP verification criteria in real procurement, risk assessment, and compliance contexts.

Selecting Verification Criteria for a Regulated Financial Workload

A cloud security practitioner at a bank is asked to evaluate two cloud providers for a workload that will process payment card data subject to PCI DSS requirements. The practitioner constructs an evidence matrix: for each provider, they request the SOC 2 Type II report (to confirm security and availability controls operated effectively over the past year), the FIPS 140-2 validation certificate for the key management service (to confirm that cryptographic modules meet the standard required for payment card data encryption), and confirmation that the infrastructure includes Common Criteria-evaluated components where the bank's IT security policy requires it. Provider A supplies a SOC 2 Type II with no exceptions in the security criterion, a FIPS 140-2 Level 3 certificate for its HSM service, and relevant Common Criteria documentation for its core network components. Provider B supplies a SOC 2 Type I and a statement that its service uses FIPS-approved algorithms but has no CMVP-validated module certificate. The practitioner recommends Provider A. Provider B's documentation does not meet the evidence standard: a Type I report does not confirm operational effectiveness, and algorithm-level claims are not equivalent to module validation. The practitioner documents the rationale in the risk acceptance record, enabling the bank's Chief Information Security Officer to make a fully informed decision.

Reviewing a SOC 2 Type II Report for Exceptions

A cloud security practitioner at a healthcare company has received a SOC 2 Type II report from a cloud data warehouse provider as part of vendor qualification. The report covers a 12-month period and includes the security and confidentiality Trust Service Criteria. The practitioner reads the report methodically, starting with the exceptions section. The report contains two exceptions: one notes that the provider's access review process was not completed for one department within the agreed quarterly schedule during the second quarter of the audit period; the other notes that one encryption key was not rotated within the provider's defined 365-day rotation policy and was rotated 14 days late. The practitioner assesses each exception. The access review delay affected a non-production internal team with no customer data access — residual risk is low. The encryption key rotation delay of 14 days, while a policy violation, did not involve a key protecting the customer data storage

layer — residual risk is assessed as low. The practitioner documents both exceptions, records the provider's stated remediation (a process control added to prevent recurrence), and recommends approval subject to a follow-up review of the next SOC 2 Type II period to confirm the remediations held. This methodical, exception-focused review is the correct professional approach to SOC 2 evaluation.

Navigating FedRAMP Impact Level Classification for a Government Workload

A cloud security practitioner advising a federal civilian agency is asked to identify suitable cloud providers for a new grants management system. The system will store personally identifiable information about grant applicants, including Social Security numbers and income data. The practitioner's first step is to classify the system under FIPS 199: the confidentiality impact of a data breach is assessed as Moderate (serious adverse effects on individuals and agency operations) and the integrity and availability impacts are assessed as Low. Under FedRAMP's impact level framework, a system with any Moderate confidentiality impact classification maps to FedRAMP Moderate. The practitioner searches the FedRAMP marketplace for providers with an authorised Moderate or High designation for the relevant service category, ruling out providers with only a FedRAMP Low authorisation or providers whose authorisation is in progress but not yet granted. Three providers hold current Moderate authorisations for the required service type. The practitioner reviews the Package Access Request for each, examining the 3PAO assessment report and the Plan of Action and Milestones to understand any open findings. One provider has two open Moderate-severity findings from the most recent annual assessment; the other two have no open findings. The practitioner recommends starting the procurement process with the two providers with clean records and documenting the basis for excluding the third. The process demonstrates that FedRAMP authorisation is not a binary pass/fail — reviewing the 3PAO assessment report and open findings is necessary to make a fully informed decision.

Best Practices

- **Always request a SOC 2 Type II report rather than a Type I or SOC 3 when evaluating a cloud provider's security controls.** SOC 3 is a public marketing summary without the control detail or testing evidence needed for security evaluation. SOC 2 Type I confirms that controls were suitably designed at a point in time but does not confirm they operated effectively. Only a SOC 2 Type II, covering a defined period (typically six to twelve months) with testing of operating effectiveness, provides the ongoing assurance necessary for cloud security due diligence. Make Type II a vendor qualification requirement.
- **Distinguish between FIPS-approved algorithm claims and FIPS 140-validated module certificates when evaluating cryptographic assurance.** A cloud provider stating that its service uses AES-256 or SHA-256 is describing algorithm selection, not module validation. FIPS 140-2 or 140-3 validation is granted by NIST to specific cryptographic module implementations after independent testing by accredited laboratories. Verify module validation certificates on the NIST CMVP list rather than accepting provider claims. For regulated workloads, require validation at the appropriate level as a contract term.
- **Classify the workload against FIPS 199 impact categories before selecting a FedRAMP-authorised provider.** Selecting a provider with a FedRAMP Moderate authorisation for a High impact workload is a risk acceptance decision that requires explicit approval, not a default. Classify the data and the system first based on the potential consequences of a confidentiality, integrity, or availability failure, then identify providers whose authorisation level matches or exceeds the classification. Do not allow platform selection to drive classification.
- **Review the exceptions section of a SOC 2 Type II report carefully before accepting it as assurance.** Exceptions are the signal in a SOC 2 report. The absence of exceptions confirms that tested controls operated as designed throughout the period. Exceptions require assessment: which control was affected,

what is the severity of the gap, what data or service did it affect, what was the provider's remediation, and has the remediation been validated in a subsequent audit? Document your exception assessment in the vendor risk record.

- **Interpret EAL ratings as measures of evaluation rigour rather than measures of security strength.** EAL7 does not mean a more secure product than EAL4; it means a more rigorously evaluated one. A product evaluated at EAL4 with sophisticated security architecture may provide stronger protection than a simpler product evaluated at EAL6. Use Common Criteria certificates as evidence that the product's security claims were independently examined at a defined level of rigour, and separately assess the security features themselves against your threat model.

Common Mistakes and Misconceptions

Misconception: Accepting a SOC 2 Type I report or a SOC 3 summary as equivalent to a SOC 2 Type II when evaluating a cloud provider.

Correct approach: SOC 2 Type I confirms control design at a point in time; SOC 3 is a public summary without testing detail. Only a SOC 2 Type II report confirms that controls operated effectively over a sustained period. For cloud security due diligence, require the Type II report and review it fully, including the exceptions section.

Misconception: Treating a cloud provider's claim to use FIPS-approved algorithms as equivalent to having FIPS 140-2 or 140-3 validated cryptographic modules.

Correct approach: Algorithm selection and module validation are distinct claims. FIPS 140 validation is granted to specific module implementations after independent laboratory testing under the NIST CMVP. Verify the certificate on the NIST CMVP list and require validation at the appropriate level as a contract term for regulated workloads.

Misconception: Assuming that FedRAMP Moderate authorisation is sufficient for any federal cloud workload without classifying the specific system and data under FIPS 199.

Correct approach: FedRAMP impact levels correspond to the potential consequences of a security failure for the specific system and data. High impact systems require FedRAMP High authorisation, which involves a substantially more demanding control baseline. Classify the workload first, then identify providers whose authorisation level is adequate. Never classify a workload to match the available provider.

Misconception: Interpreting a higher EAL number as indicating a more secure product.

Correct approach: EAL ratings measure the rigour of the evaluation methodology, not the strength of the security architecture. A product at EAL7 has been subjected to the most formal verification, but a simpler product with a weaker architecture evaluated at EAL7 may protect data less effectively than a well-designed product at EAL4. Assess security features independently of the EAL rating.

table: CSP Verification Criteria Quick Reference

Use this table to identify which assurance framework applies to each layer of cloud provider evaluation and what the key decision criteria are for each.

Framework	What It Evaluates	Key Output / Rating	How to Use in CSP Evaluation
Common Criteria (ISO/IEC 15408)	Security properties of specific IT products (HSMs, OS, firewalls)	EAL1-EAL7 certificate from accredited lab	Verify EAL rating and Protection Profile for security-critical components; EAL measures

			evaluation rigour, not security strength
FIPS 140-2 / 140-3	Cryptographic module implementations	Level 1-4 certificate on NIST CMVP list	Verify certificate on NIST CMVP; distinguish from algorithm-only claims; require Level 2+ for most regulated use cases, Level 3+ for high-sensitivity key management
FedRAMP	Cloud services for US federal government use	Low / Moderate / High authorisation via 3PAO assessment	Classify workload under FIPS 199 first; require matching or higher impact level; review 3PAO report and open Plan of Action and Milestones findings
SOC 2 Type II	Security, availability, processing integrity, confidentiality, privacy controls over time	Auditor report with exceptions noted	Always request Type II (not Type I or SOC 3); review exceptions section carefully; verify scope covers services in use; repeat annually
SOC 1	Controls relevant to financial reporting	Type I or Type II report	Relevant only if the provider processes financial transactions on your behalf; not a substitute for SOC 2 when evaluating cloud security posture
SOC 3	Public summary of SOC 2 findings	Summary report (no detailed testing evidence)	Marketing value only; insufficient for security due diligence; always request the full SOC 2 Type II

How to use this: No single framework covers the full CSP evaluation picture. A rigorous evaluation uses multiple frameworks in combination: SOC 2 Type II for operational controls, FIPS 140 for cryptographic modules, and FedRAMP or Common Criteria where regulatory requirements or product-level assurance needs apply.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A cloud provider states that its hardware security module service holds a Common Criteria EAL4+ certificate. A security architect evaluating the provider for a financial services workload interprets this as meaning the HSM is more secure than a competing HSM with an EAL2 certificate. Which of the following best describes the architect's interpretation?

- A) A. The interpretation is correct; EAL4+ confirms that the HSM's security is stronger than that of an EAL2-rated product.
- B) B. The interpretation is incorrect; EAL ratings measure the rigour of the evaluation methodology, not the strength of the security architecture.
- C) C. The interpretation is correct if the Protection Profile for both evaluations is identical.
- D) D. The interpretation is incorrect because EAL4 is not a recognised EAL level; only EAL1 through EAL3 are commercially available.

Answer: B. The interpretation is incorrect; EAL ratings measure the rigour of the evaluation methodology, not the strength of the security architecture.

Q2. A cloud provider's security documentation states that all data at rest is protected using AES-256 encryption with FIPS-approved algorithms. A security officer at a federal agency considers this sufficient assurance for a Moderate impact workload. Which of the following best describes the adequacy of this claim?

- A) A. The claim is sufficient; AES-256 is a strong algorithm and its use with FIPS-approved parameters satisfies FIPS 140-2 requirements.
- B) B. The claim is insufficient; using FIPS-approved algorithms is not the same as having a FIPS 140-2 validated cryptographic module. The officer should verify the CMVP certificate.
- C) C. The claim is sufficient for a Moderate impact workload but would require FIPS 140-2 Level 4 validation for a High impact workload.
- D) D. The claim is insufficient only if the agency requires FIPS 140-3 specifically; FIPS 140-2 algorithm claims satisfy FIPS 140-3 requirements by default.

Answer: B. The claim is insufficient; using FIPS-approved algorithms is not the same as having a FIPS 140-2 validated cryptographic module. The officer should verify the CMVP certificate.

Q3. A security team is evaluating a cloud provider for a workload that will process grants data including Social Security numbers. Under FIPS 199, the confidentiality impact is assessed as Moderate. The team is considering two providers: one with a FedRAMP Low authorisation and one with a FedRAMP Moderate authorisation. Which provider is appropriate and why?

- A) A. The FedRAMP Low provider is appropriate because the system's availability impact is assessed as Low.
- B) B. The FedRAMP Moderate provider is appropriate because the system's highest impact category (confidentiality at Moderate) determines the required authorisation level.
- C) C. Either provider is appropriate because FedRAMP Low and Moderate authorisations cover the same control baseline.
- D) D. Neither provider is appropriate; a new FedRAMP assessment must be conducted specifically for this workload.

Answer: B. The FedRAMP Moderate provider is appropriate because the system's highest impact category (confidentiality at Moderate) determines the required authorisation level.

Q4. A vendor provides a SOC 2 Type I report as part of a cloud service procurement process. A security practitioner on the procurement team requests a SOC 2 Type II report instead. The vendor argues that the Type I report confirms their controls are suitably designed and is sufficient for procurement purposes. Which of the following best supports the practitioner's position?

- A) A. The practitioner's position is incorrect; a Type I report is the standard for procurement and a Type II is required only for annual compliance reviews.
- B) B. The practitioner's position is correct; a Type I report confirms control design at a single point in time but does not confirm that controls operated effectively over a sustained period.
- C) C. The practitioner's position is incorrect; Type I and Type II reports test the same controls and provide equivalent assurance.
- D) D. The practitioner's position is correct; SOC 2 Type II is required by all major regulatory frameworks and a Type I report has no recognised assurance value.

Answer: B. The practitioner's position is correct; a Type I report confirms control design at a single point in time but does not confirm that controls operated effectively over a sustained period.

Q5. A cloud security practitioner reviewing a SOC 2 Type II report notices that the exceptions section documents one finding: the provider's encryption key rotation process was completed 14 days later than the provider's own 90-day policy for one key, which was not used to protect customer data. What is the correct approach to this finding?

- A) A. Reject the provider immediately because any exception in a SOC 2 report is grounds for disqualification.

- B) B. Assess the exception by considering what control was affected, what data was at risk, the severity of the delay, and the provider's documented remediation; then make a risk-based decision.
- C) C. Accept the report without further review because the exception did not involve customer data.
- D) D. Request that the provider waive the exception from the next SOC 2 period to ensure it does not recur.

Answer: B. Assess the exception by considering what control was affected, what data was at risk, the severity of the delay, and the provider's documented remediation; then make a risk-based decision.

Reflection Questions

1. Consider the last cloud provider your organisation evaluated or currently uses. What assurance documentation was collected? Was it a SOC 2 Type I or Type II? Were any exceptions reviewed, or was the report accepted without detailed examination?
2. Think about the cryptographic modules protecting the most sensitive data in your current cloud environment. Does the provider have FIPS 140-2 or 140-3 validation for those specific modules? Have you verified this on the NIST CMVP list, or is the assurance based on the provider's documentation alone?
3. If your organisation were subject to FedRAMP requirements, how would you classify your most sensitive cloud workload under FIPS 199? Would the cloud provider you currently use have the appropriate impact level authorisation?
4. Consider a situation where a vendor provides a SOC 3 report and argues that it demonstrates their security posture is strong. What would you say to the vendor, and what would you require instead?
5. Think about the distinction between EAL ratings and security strength. If a security team member used a higher EAL number to argue for selecting one hardware security module over another, how would you guide their interpretation?

Key Takeaways

- Common Criteria EAL ratings measure the rigour of the security evaluation methodology, not the strength of the product's security features. EAL4 is the highest level commonly found in commercial products.
- FIPS 140-2 and 140-3 validate cryptographic module implementations, not algorithm selections. Verify validation certificates on the NIST CMVP list; do not accept algorithm-level claims as equivalent.
- FedRAMP impact levels align to FIPS 199: Low, Moderate, and High. Approximately 80 percent of federal systems are Moderate. Classify the workload first; select the provider second.
- 3PAOs are accredited, independent organisations that conduct FedRAMP assessments. Their assessment reports are the evidentiary basis for authorisation, not the provider's self-attestation.
- SOC 2 Type II reports are the primary cloud security assurance artefact in commercial contexts. Always request Type II; never accept a Type I or SOC 3 as a substitute for security evaluation.
- SOC 2 Type II exceptions require individual risk assessment, not automatic rejection or automatic acceptance. The severity of an exception depends on what control was affected and what data was at risk.
- SOC 1 addresses financial reporting controls and is not a substitute for SOC 2 when evaluating cloud security posture.
- No single framework covers the complete CSP evaluation picture. A rigorous evaluation combines multiple frameworks: SOC 2 Type II for operational controls, FIPS 140 for cryptographic modules, and FedRAMP or Common Criteria where regulatory or product-level requirements apply.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Identify the most sensitive cloud workload in your current environment and request the SOC 2 Type II report for the cloud provider hosting it. Review the exceptions section and document your risk assessment for each exception in the vendor risk register.
7. Verify whether the key management or HSM service used for your most sensitive cloud workload holds a FIPS 140-2 or 140-3 validated module certificate by searching the NIST CMVP list. If the provider's certificate cannot be located, raise this as a gap in the vendor risk register.
8. If your organisation hosts workloads subject to US federal requirements or equivalent regulated frameworks, classify each workload under a FIPS 199 equivalent framework and map the classification to the required provider assurance level. Document any mismatches between current provider authorisations and required levels.
9. Review your organisation's vendor qualification process for cloud providers this month. Confirm that SOC 2 Type II (not Type I or SOC 3) is a documented requirement, that exception review is a defined step, and that FIPS 140 validation is a requirement for workloads handling sensitive or regulated data.